

# **Internet das Coisas**

## **Introdução: Riscos e segurança**

**Professor:**

**Vinícius Fernandes Soares Mota**

[inf.ufes.br/~vinicius.mota](http://inf.ufes.br/~vinicius.mota)

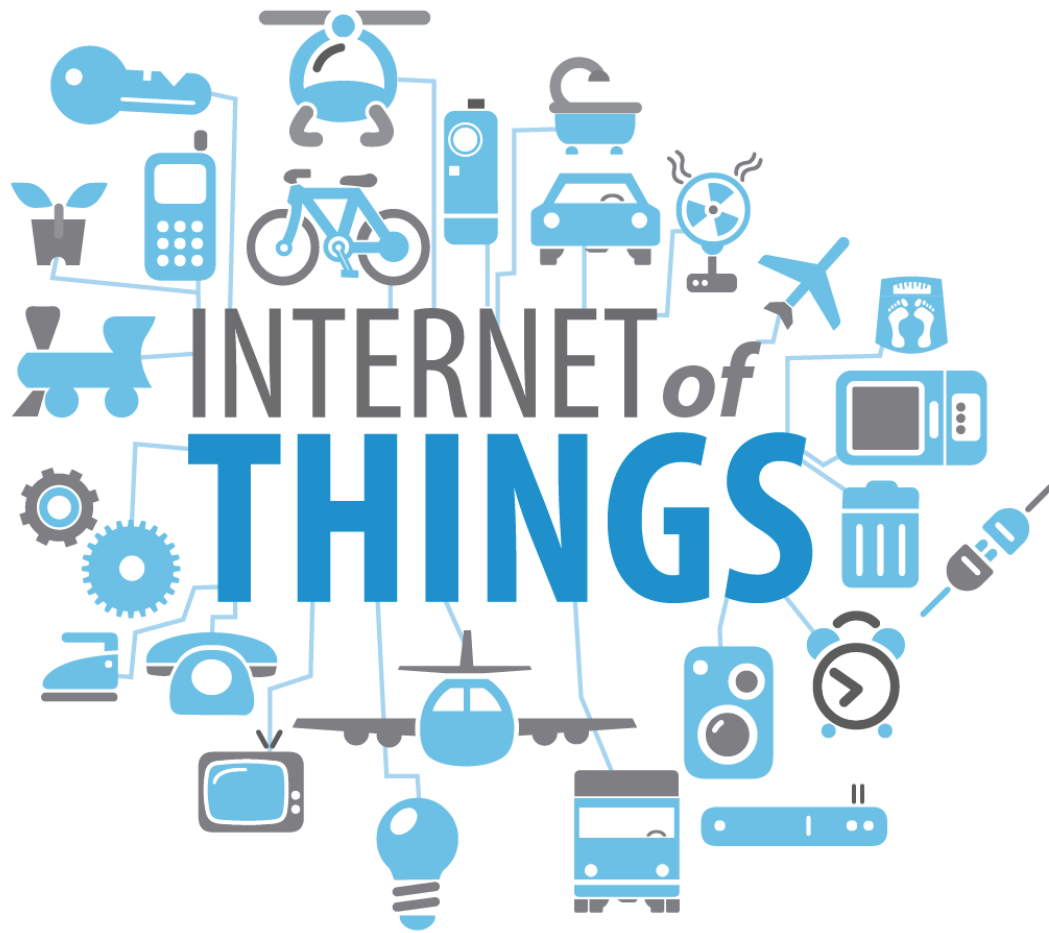
[vinicius.mota@inf.ufes.br](mailto:vinicius.mota@inf.ufes.br)

CT-7 Sala 8

- Sob licença Creative Commons Attribution-NonCommercial-ShareAlike 4.0 International License.

Slides baseados nos materiais gentilmente cedidos pelo Professor José Marcos Silva Nogueira – DCC/UFMG e pelo autor do Minicurso: Internet das Coisas – da Teoria a prática, SBRC 2016, Bruno Pereira Santos et al.

Livro Sunil Cheruvu et al. Demystifying Internet of Things Security. 2020.

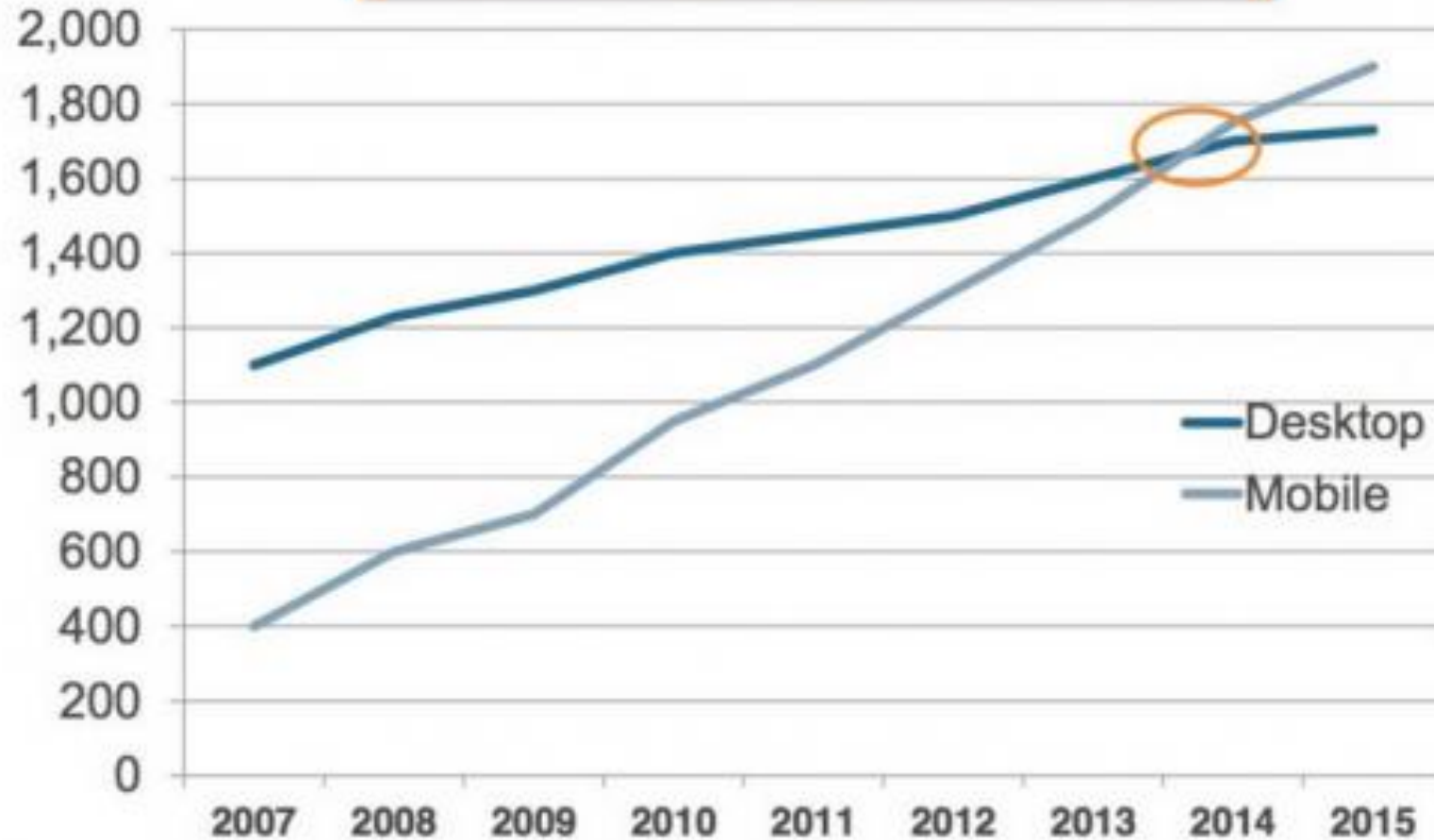


Coisas comunicando com Coisas são o que formam a Internet das coisas!!!!

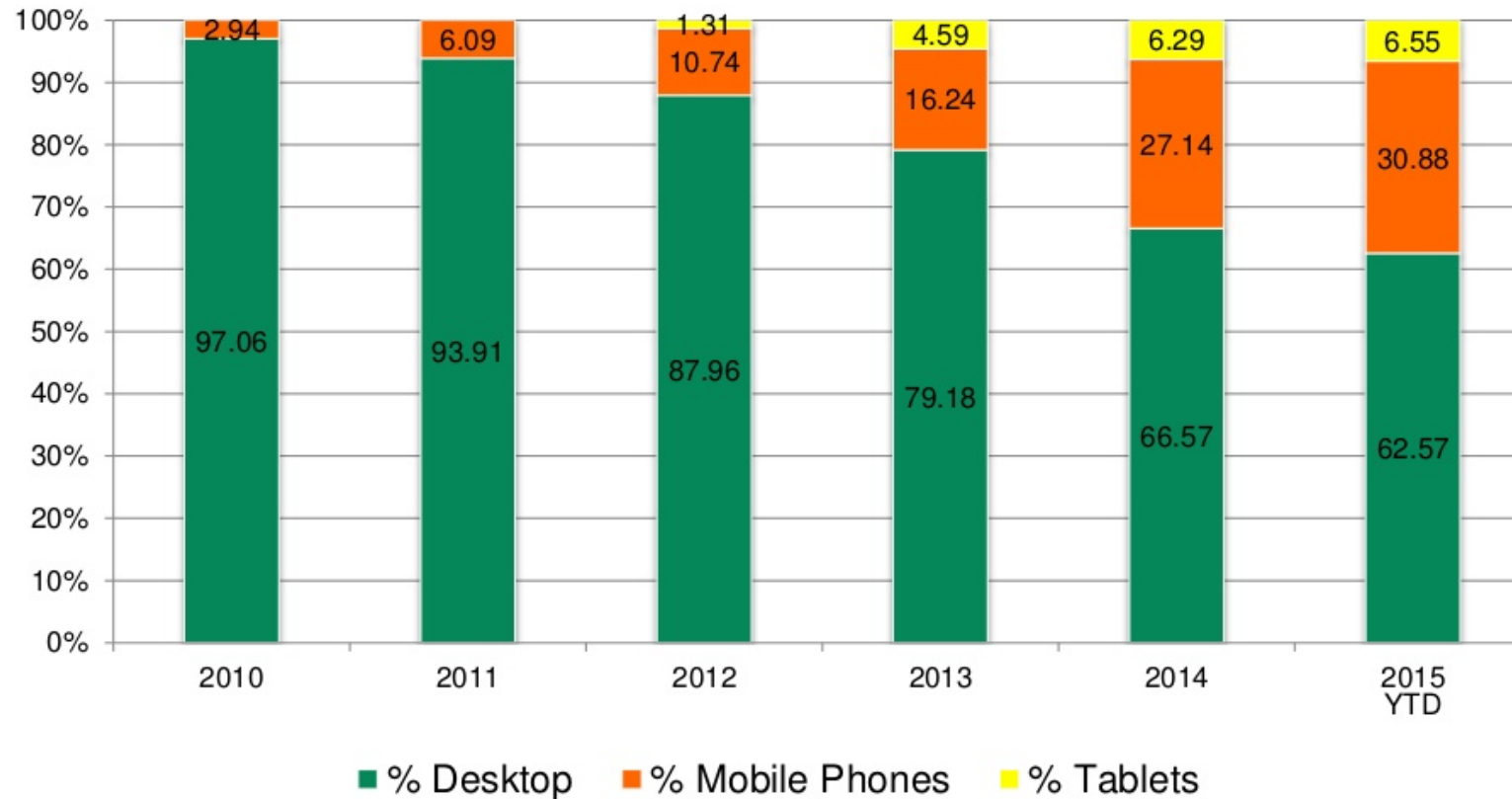
# Muitas soluções, antigos problemas!!

**O objetivo da aula de hoje é discutir algumas ameaças que a era de objetos conectados trouxe à computação!!**

## Number of Global Users (Millions)

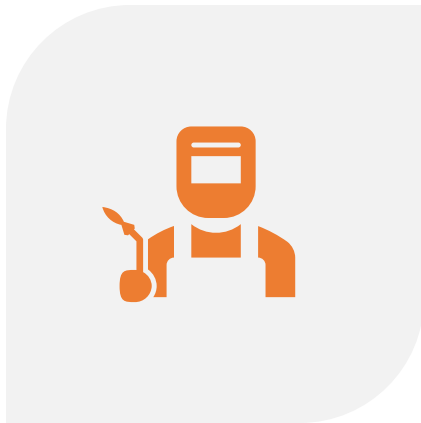


# Open Web Trends (Global): Computers vs. Mobile Internet Traffic, 2010-2015

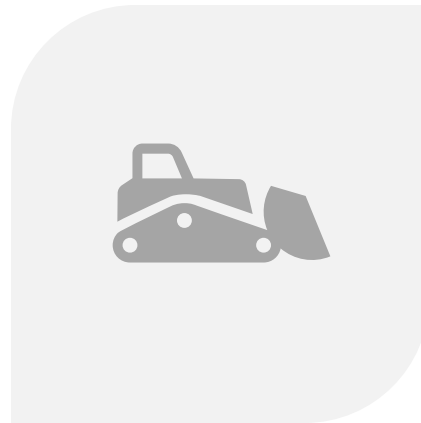


Data Source: Global Stats: StatCounter GlobalStats <http://gs.statcounter.com>

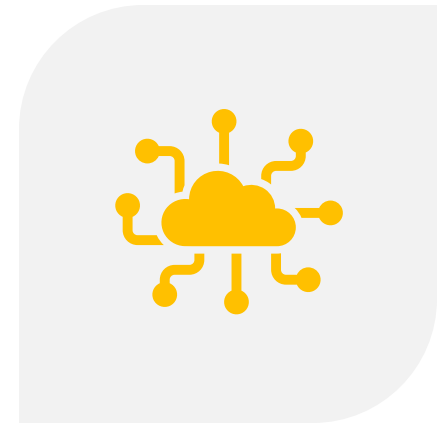
# The Internet of Things



MUITO ALÉM DE PESSOAS, MÁQUINAS  
CONECTANDO E FAZENDO O SERVIÇO



SE MÁQUINAS PODEM SE CONECTAR, ENTÃO  
NOS PRÓXIMOS ANOS PODE-SE CHEGAR A  
CENTENA DE MILHÕES DE MÁQUINAS



BILHÕES DE MÁQUINAS CONECTADAS  
PODERÍAMOS Atingir A UBIQUIDADE

Ubiquitous networks **take mobile networks one step further**, embedding short-range mobile transceivers into a wide array of **additional gadgets and everyday items**, enabling new forms of collaboration and communication between people and things, and between things themselves.

This is the vision of a truly ubiquitous network  
—*“anytime, anywhere, by anyone and anything”*

## Isolamento social





- Dependência de Infraestrutura
  - IoT depende de rede
  - Suscetível a falhas

- Dependência de Infraestrutura
  - IoT depende de rede
  - Suscetível a falhas



- Dependência de Infraestrutura
  - IoT depende de rede
  - Suscetível a falhas



# Ubiquidade e IoT: Riscos

- Dependência de Infraestrutura
  - IoT depende de rede
  - Suscetível a falhas



- IoT é pervarsivo
  - Localização: smart phones
  - Saúde: Utilização dos dados
  - Hábitos de mídia: Smart TV / TV on Demand
  - Hábitos de compra: Cartão de crédito
  - Hábitos de direção: sistemas de navegação

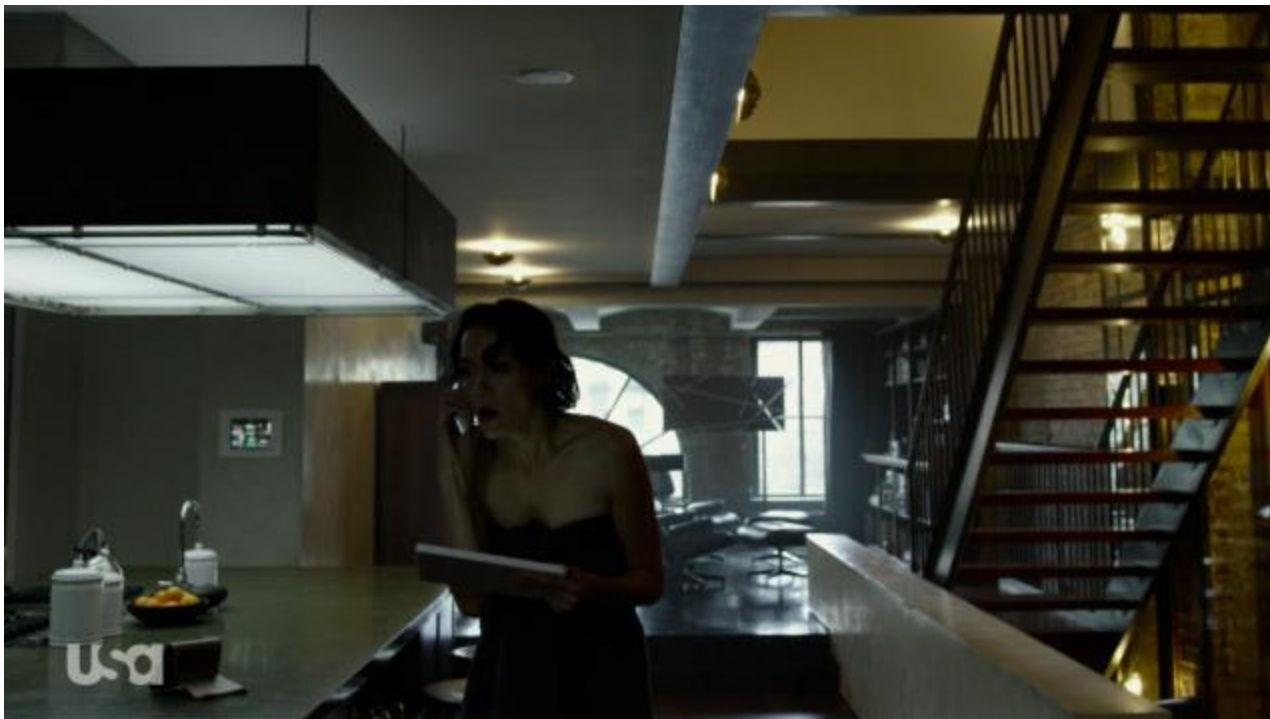
# Ubiquidade e IoT: Segurança

- Smart Home



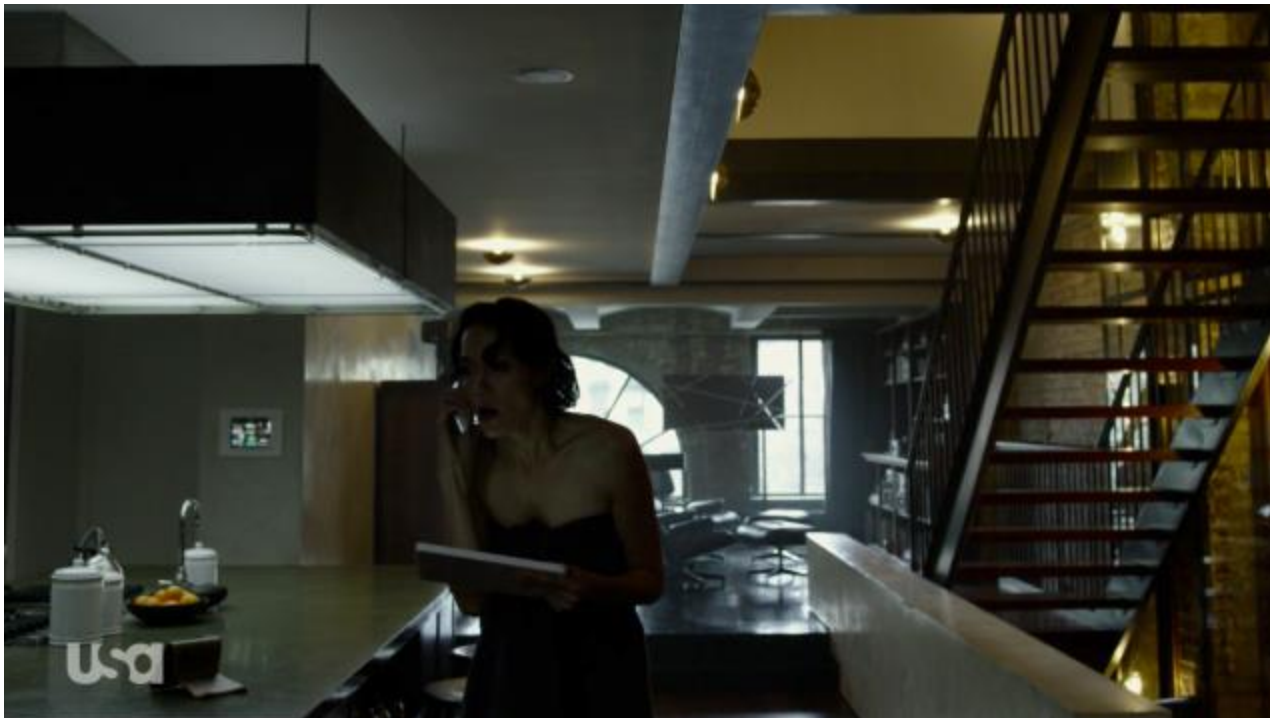
# Ubiquidade e IoT: Segurança

- Smart Home



# Ubiquidade e IoT: Segurança

- Smart Home



**MR. ROBOT**



- Smart Home

## **Samsumg Smart Things**

### **Pesquisadores de Michigan testaram 500 SmartApps**

Explorar vulnerabilidade em 40% dos SmartApps

- Configurar novas senhas
- Desligar modo férias e ser capaz de programar hora de ligar lampadas
- Alterar alarme de alguns dispositivos injetando falsas mensagens

<http://ns.umich.edu/new/multimedia/videos/23748-hacking-into-homes-smart-home-security-flaws-found-in-popular-system>

“The Internet of Things can be described as a dynamic set of distributed computing coalition groups that come into existence seemingly on their own, without a presumption of central control or orchestration.”

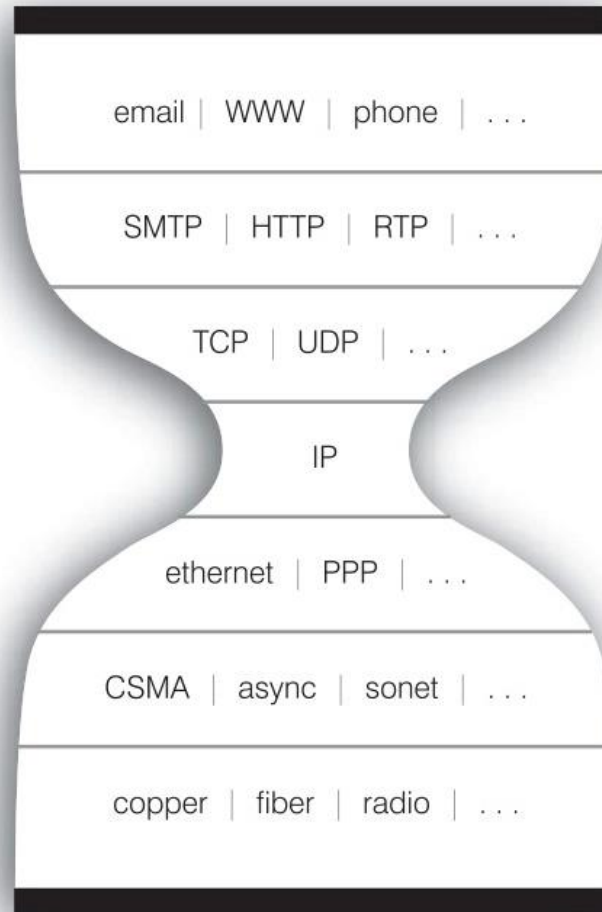
Sunil Cheruvu et al. Demystifying Internet of Things Security

- IoT !
  - Regulamentações e padronizações
    - *Plug & Play*
  - Segurança e privacidade
    - “A segurança dos objetos inteligentes é tão forte quanto seu enlace mais fraco” - Dominique Guinard.

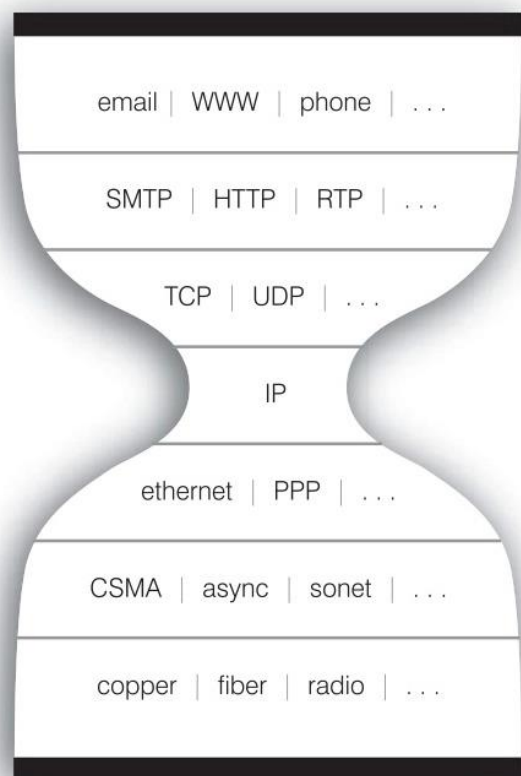
- IoT agora!
  - Regulamentações e padronizações
    - *Plug & Play*
  - Segurança e privacidade
    - “A segurança dos objetos inteligentes é tão forte quanto seu enlace mais fraco” - Dominique Guinard.
- O desafio é transformar dado em conhecimento que tem valor

# Pensando em segurança na Internet

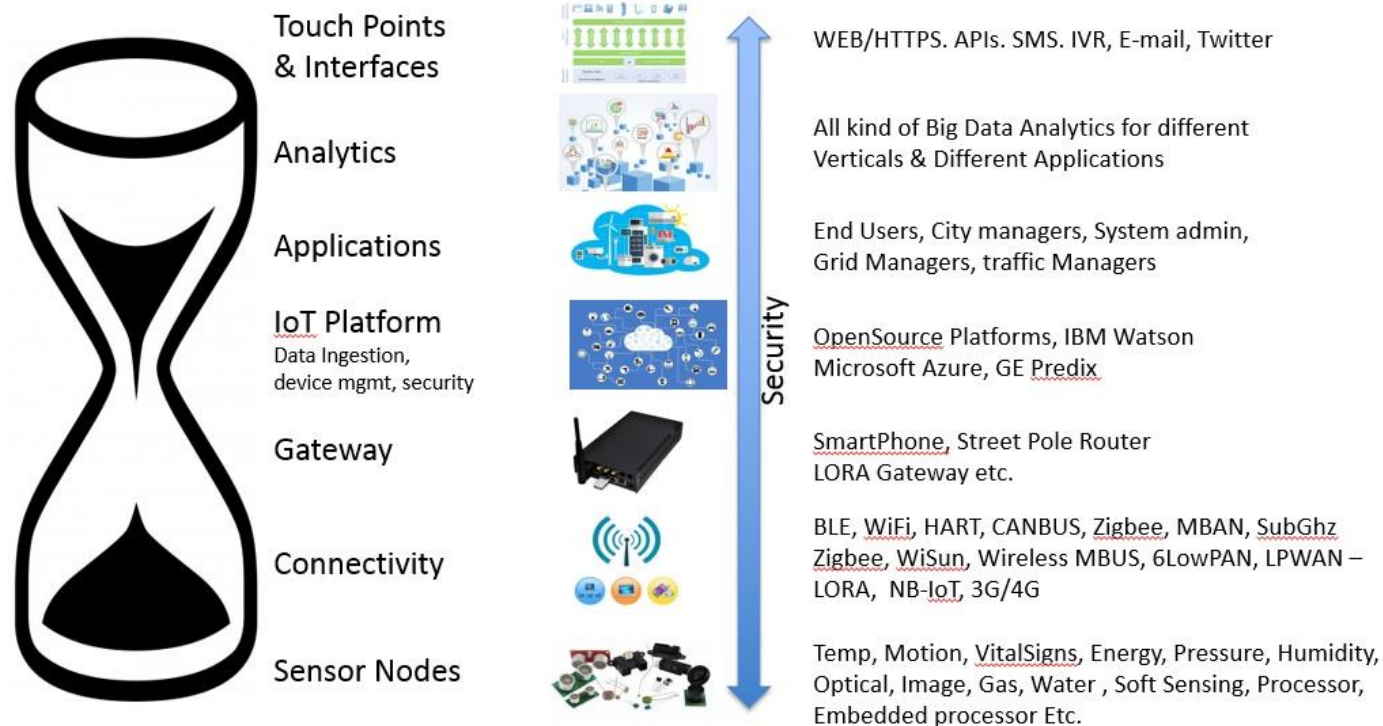
Relembrando o modelo ampulheta da Internet



# Pensando em segurança IoT

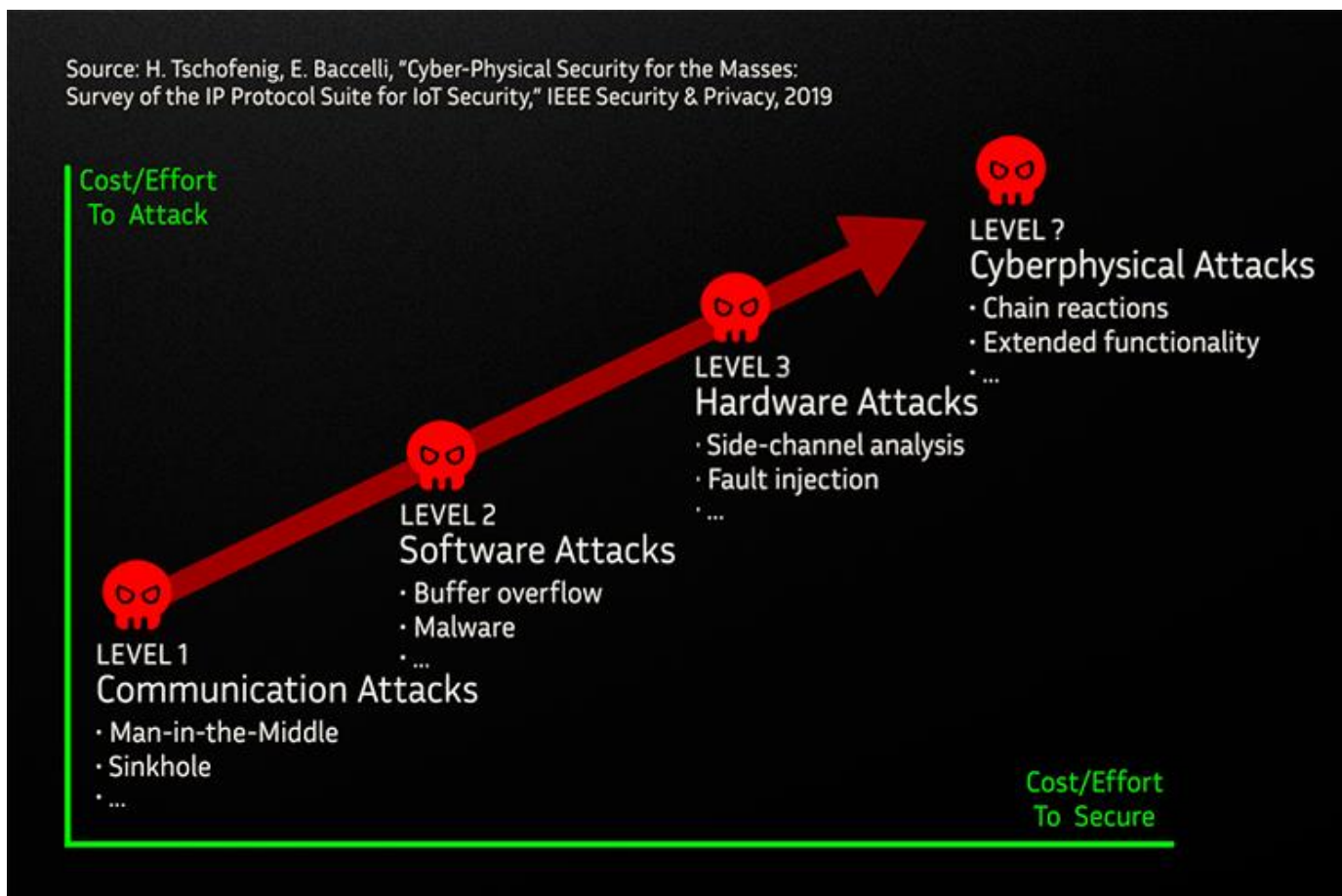


## Sensor to the Cloud - The IoT Stack!



# Pensando em segurança IoT

Para proteger dispositivos IoT, deve-se considerar ataques de natureza diversa.



# Pirâmide de segurança IoT

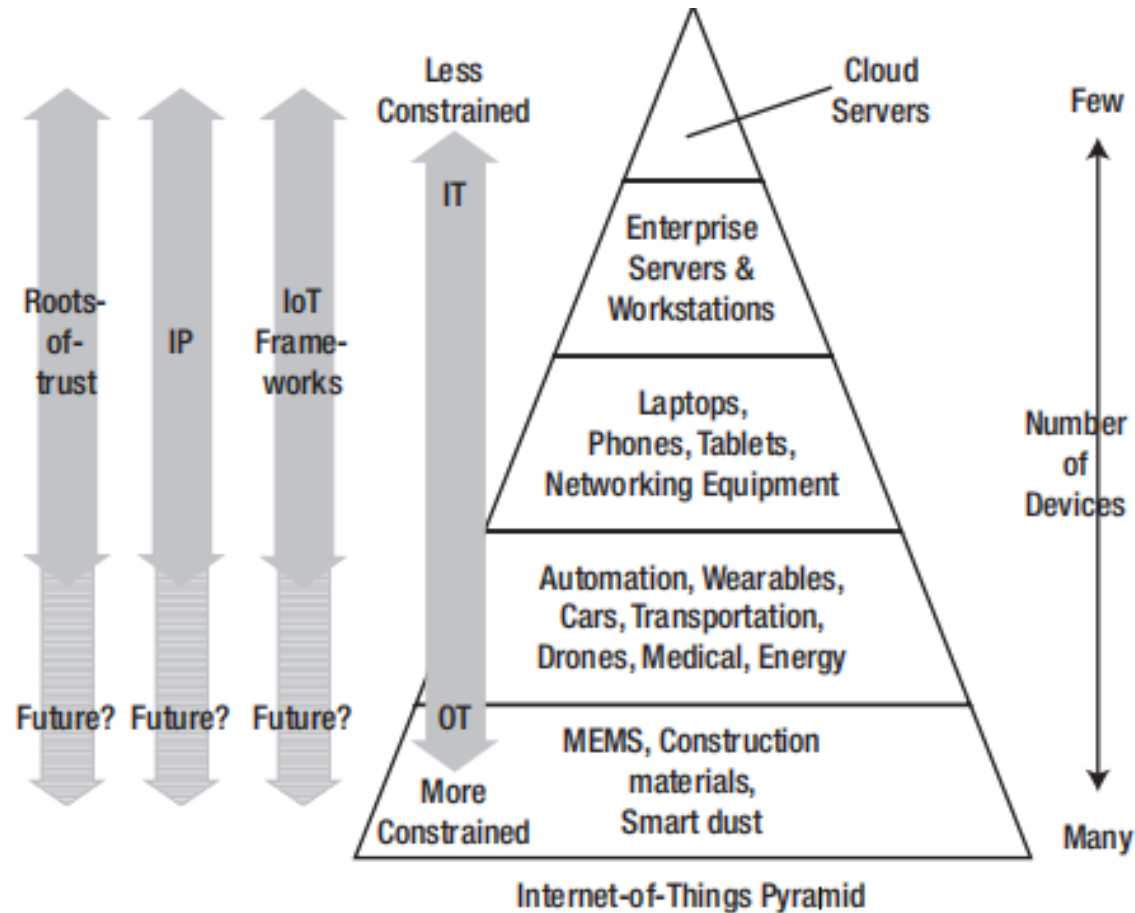
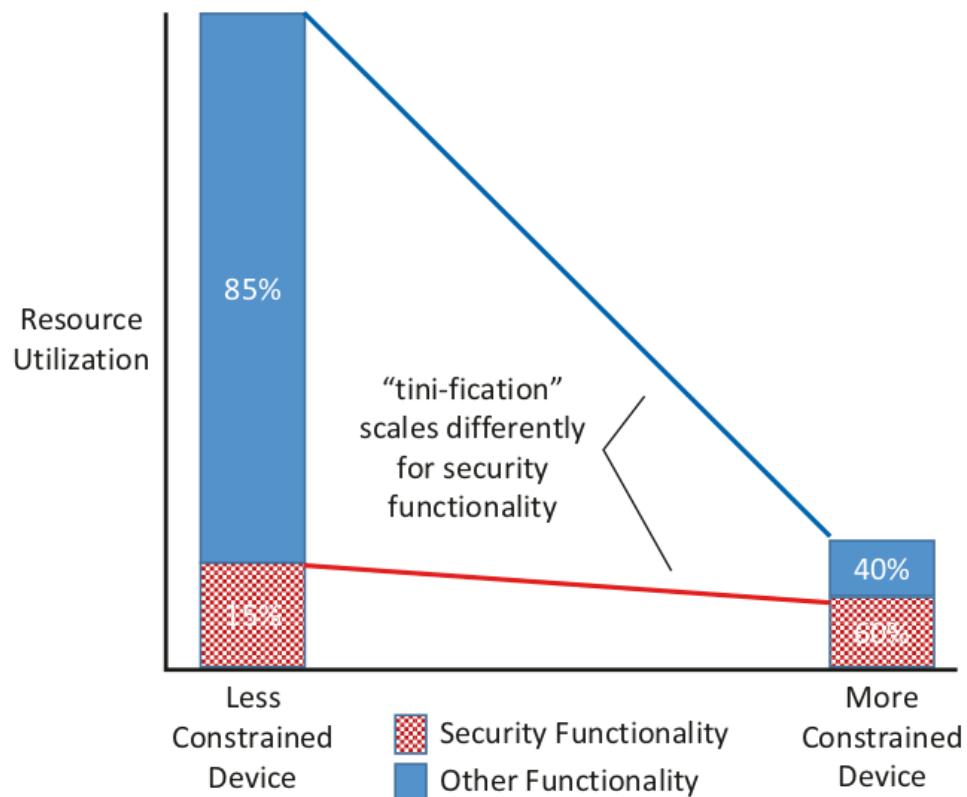


Fig 1.1 - Sunil Cheruvu et al. Demystifying Internet of Things Security





**Figure 1-2.** Nonlinear “tini-fication” of security vs. other functionality

Sunil Cheruvu et al. Demystifying Internet of Things Security

## Os mecanismos de segurança devem:

- requerer  $10^6$  menos memória (RAM e Flash);
- requerer  $10^6$  menos (controle e usuário) taxa de transferência de tráfego;
- suportar tamanho de pacote muito menor (muito eficiente);
- funcionar com CPU muito mais fraca,  $10^3$  mais lenta ou menos;
- fator humano é diferente (não relação 1:1 para humanos/máquinas);
- o armazenamento seguro de segredos (por exemplo, chaves criptográficas) é um desafio no dispositivo IoT de baixo custo simplista.

A segurança da IoT na prática deve combinar

- vários mecanismos de defesa,
- trabalhar em diferentes níveis do sistema, e
- proteção contra diversos tipos de ataques.

**Cada um desses mecanismos de defesa é necessário, mas não suficiente para alcançar a segurança geral.**

- Na prática, o foco será sempre em:
- defender contra ataques de rede e
- defender contra alguns ataques de software com base na instalação remota de malware.

Primitivas apropriadas para garantias básicas em dados digitais em IoT

- **Autenticidade:** garantia sobre a origem dos dados;
- **Integridade:** garantir que os dados originais não foram adulterados;
- **Confidencialidade:** garantir que os dados sejam inteligíveis apenas para os destinatários pretendidos.

Os blocos de construção típicos são:

**Hash:** dados de mapeamento de função de tamanho arbitrário para valores de tamanho fixo (menores); ver [https://www.di-mgt.com.au/sha\\_testvectors.html](https://www.di-mgt.com.au/sha_testvectors.html)

**Criptografia:** conjunto de algoritmos que permitem ao originador (resp. destinatário) dos dados digitais codificar (resp. decifrar) esses dados usando uma ou mais chaves.

**Assinatura Digital:** conjunto de algoritmos que permitem geração de chave (privada/pública), geração de assinatura com base em chave privada e verificação de autenticidade com base em chave pública.

**Uma implementação para ESPs pode ser encontrada em:**

<https://github.com/CSSHL/ESP8266-Arduino-cryptolibs/tree/master/sha256>

# Uma rede de objetos confiáveis

*“The Internet of Things can be described as a dynamic set of distributed computing coalition groups that come into existence seemingly on their own, without a presumption of central control or orchestration.”*

Sunil Cheruvu et al. Demystifying Internet of Things Security

Garantir que um objeto é confiável: **Protocolos de atestações**

Um algoritmo simples: *Root-of-trust*

Uma chave definida pelo fabricante e embarcada no dispositivo.

- Requer armazenamento de chave seguro;
- Operações de criptografia;

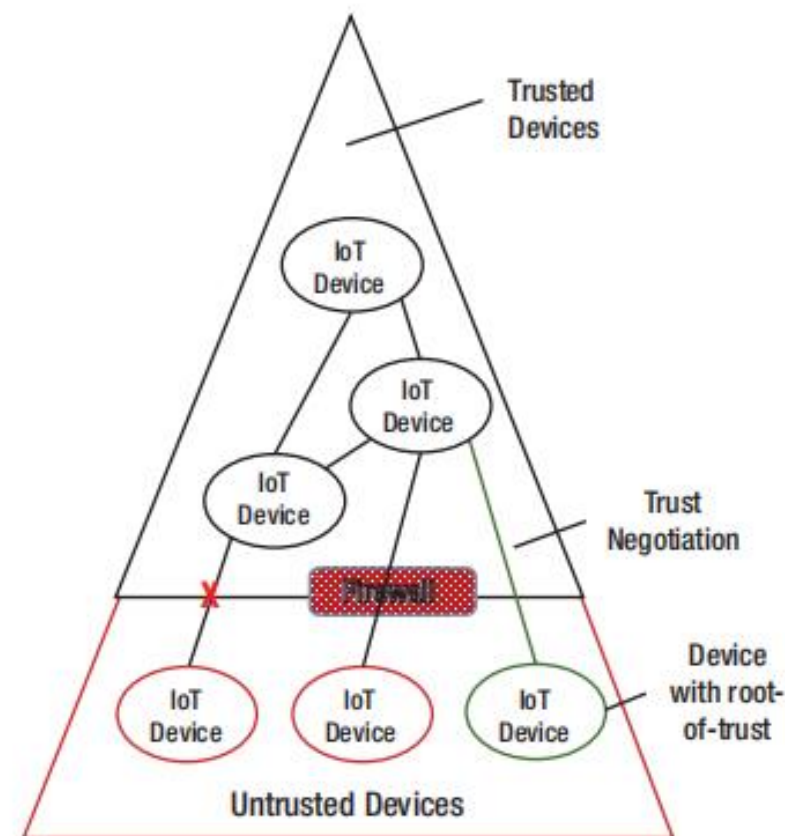


Fig 1.4 Sunil Cheruvu et al. Demystifying Internet of Things Security

# Uma rede de objetos confiáveis

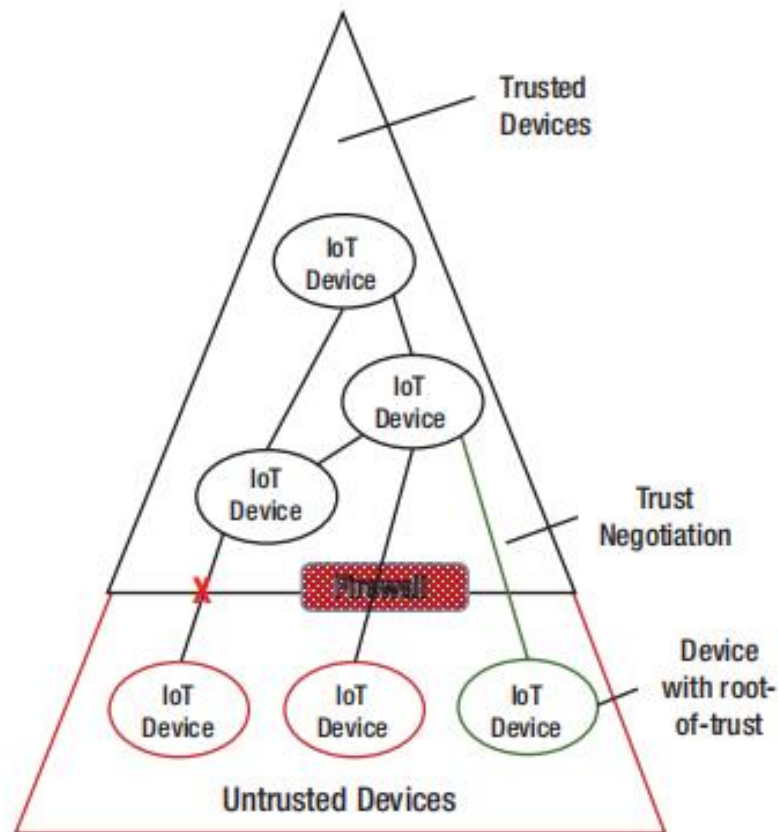
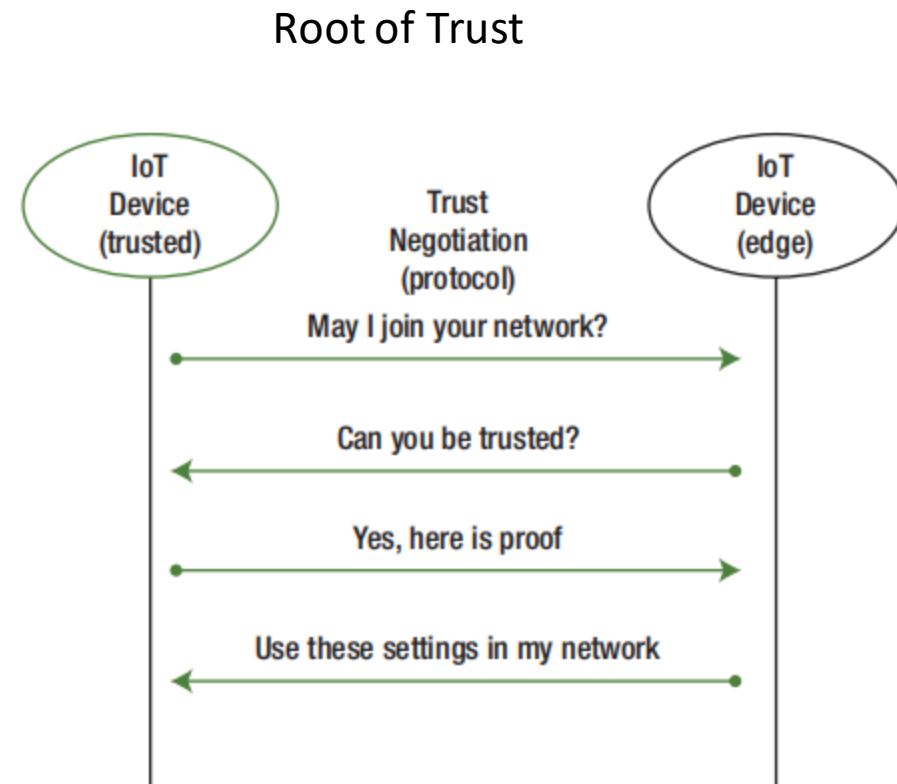
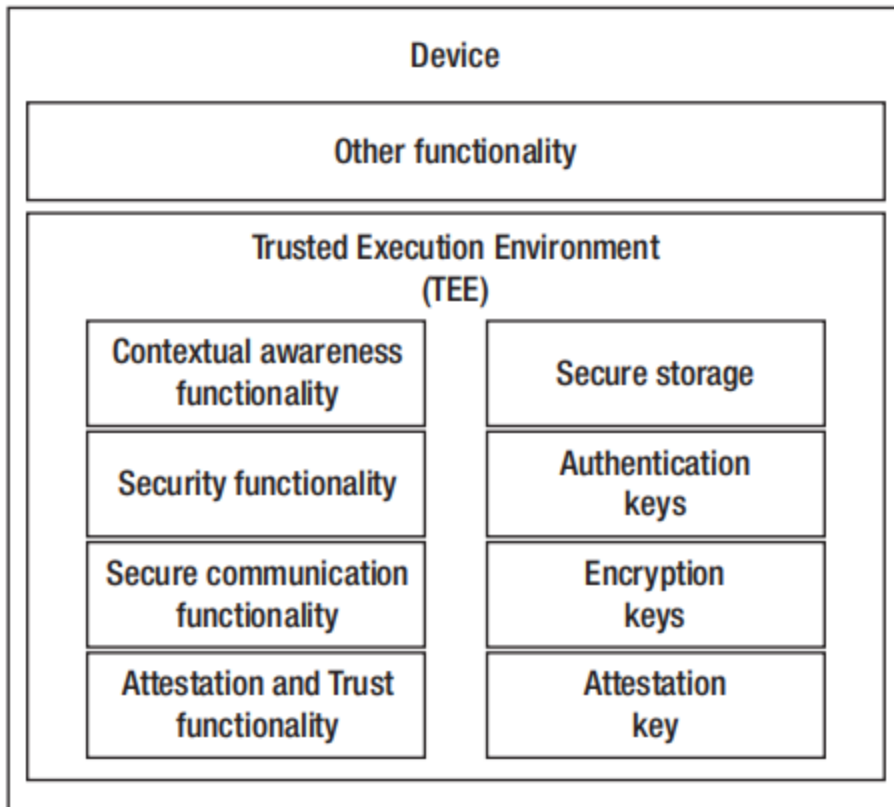


Fig 1.4 Desmystifying IoT Security



# Design de uma arquitetura confiável

Dispositivos podem garantir que são confiáveis Por meio de um Trusted Execution Environment (TEE)



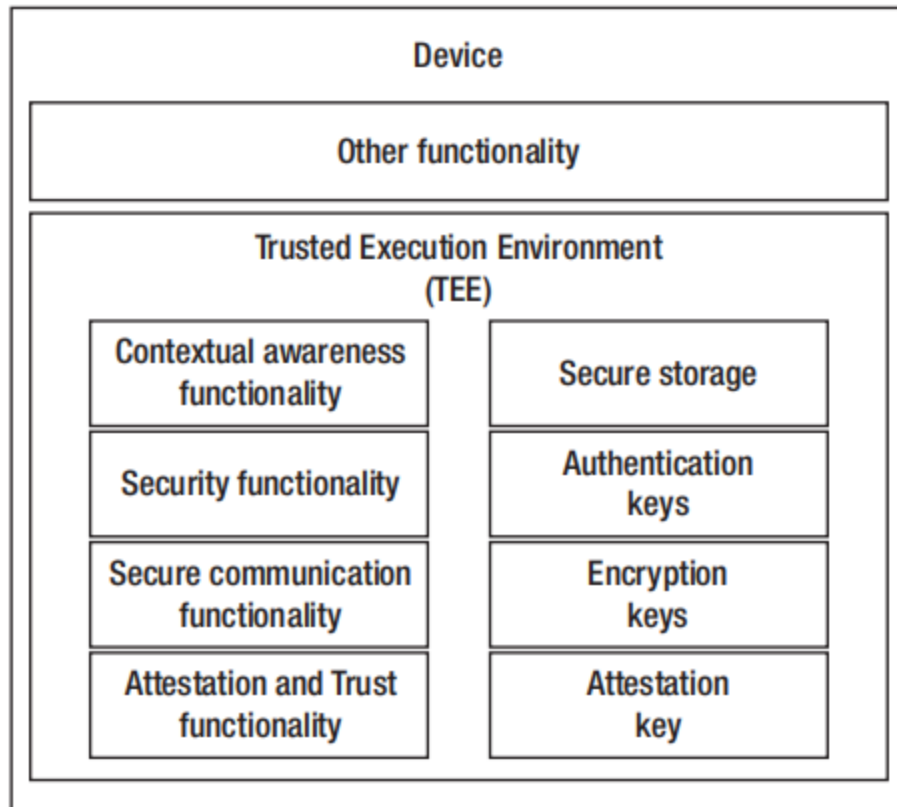
## Ambiente de Execução Confiável (TEE)

Uma área segura de um processador principal. Ele garante que o código e os dados sejam protegidos com respeito à confidencialidade e integridade.

Um TEE fornece recursos de segurança como execução isolada, integridade de aplicativos executados com o TEE, juntamente com confidencialidade de seus ativos.

# Design de uma arquitetura confiável

Sunil Cheruvu et al. defendem que os dispositivos devem ter a seguinte arquitetura para que possam se provar confiáveis.



**(A) Attestation key:** An asymmetric key supplied by the device manufacturer that establishes device origin authenticity.

**(B) Attestation functionality:** Trusted code that implements attestation and attestation verification logic.

**(C) Encryption keys:** Symmetric and asymmetric keys used to protect device-device and device-human interactions that may occur in the context of a coalition.

**(D) Secure communication:** Trusted code that implements cryptographic algorithms used to protect the confidentiality and integrity of information exchanged between devices and TCB peers.

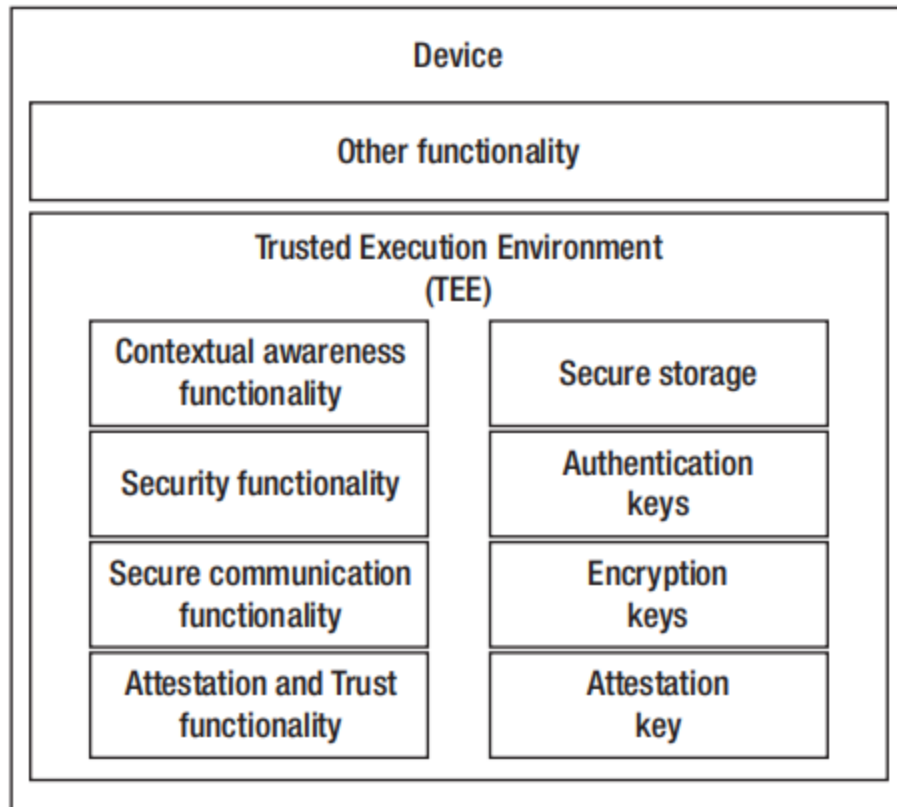
**(E) Authentication keys:** Symmetric and asymmetric keys used to authenticate the originators of messages exchanged device-device and device-human, also in the context of a coalition.

**(F) Authentication functionality:** Trusted code that implements identity and authentication primitives including support for distributed authentication protocols such as OAuth234 and OpenID Connect.



# Design de uma arquitetura confiável

Sunil Cheruvu et al. defendem que os dispositivos devem ter a seguinte arquitetura para que possam se provar confiáveis.



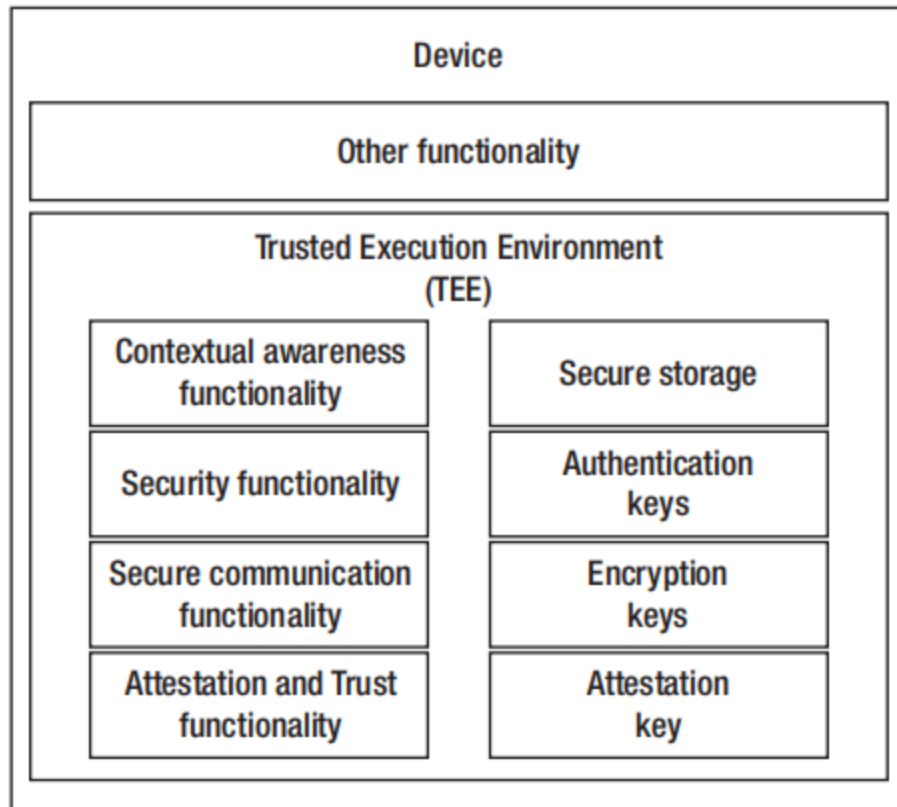
**(G) Secure storage:** The ability to store keys, integrity measurements (cryptographic hash), whitelists, settings, and contextual information that if modified or deleted could result in failure of the TCB to correctly apply a security objective.

**(H) Contextual awareness functionality:** Trusted code that can encrypt and authenticate stored data securely even if the attacker has physical access to the storage resource. The ability to sense and collect security relevant context such as time, location, biometrics, and other context.

**(I) Trusted execution environment functionality:** Trusted code that correctly implements the TEE environment such that the TEE firmware can be updated securely and computing interfaces into the TEE are resistant to attack

# Design de uma arquitetura confiável

Sunil Cheruvu et al. defendem que os dispositivos devem ter a seguinte arquitetura para que possam se provar confiáveis.



Hardwares que suportam TEE (Fonte: Wikipedia):

- AMD:
  - Platform Security Processor (PSP)
  - AMD Secure Encrypted Virtualization and the Secure Nested Paging extension
- ARM:
  - TrustZone
  - Realm Management Extension / Confidential Compute Architecture (CCA)
- IBM:
  - IBM Secure Service Container, formerly zACI, first introduced in IBM z13 generation machines (including all LinuxONE machines) in driver level 27.
  - IBM Secure Execution, introduced in IBM z15 and LinuxONE III generation machines on April 14, 2020.
- Intel:
  - Trusted Execution Technology
  - SGX Software Guard Extensions
  - "Silent Lake" (available on Atom processors)
- RISC-V:
  - MultiZone™ Security Trusted Execution Environment
  - Keystone Customizable TEE Framework
  - Penglai Scalable TEE for RISC-V

## Capítulo 1 - Sunil Cheruvu et al. Demystifying Internet of Things Security

Fernandes, Earlence, Jaeyeon Jung, and Atul Prakash. "Security Analysis of Emerging Smart Home Applications." (2016).

# Dúvidas?

*Internet das Coisas*  
**Ubiquidade e segurança**

**Vinícius Fernandes Soares Mota**